

Broken Object Level Authorization

Web APIs allow users to request data or records by sending various parameters, including unique identifiers (UUIDs), also known as Globally Unique Identifiers (GUIDs), and integer IDs. However, fail to verify that a user has ownership and permission to view a specific resource through object-level authorization, leading to data exposure and security vulnerabilities.

A web API endpoint is vulnerable to Broken Object Level Authorization (BOLA), also known as Insecure Direct Object Reference (IDOR), if its authorization checks (implemented at the source-code level) fail to correctly ensure that an authenticated user has the permissions or privileges to request and view specific data or perform certain operations.

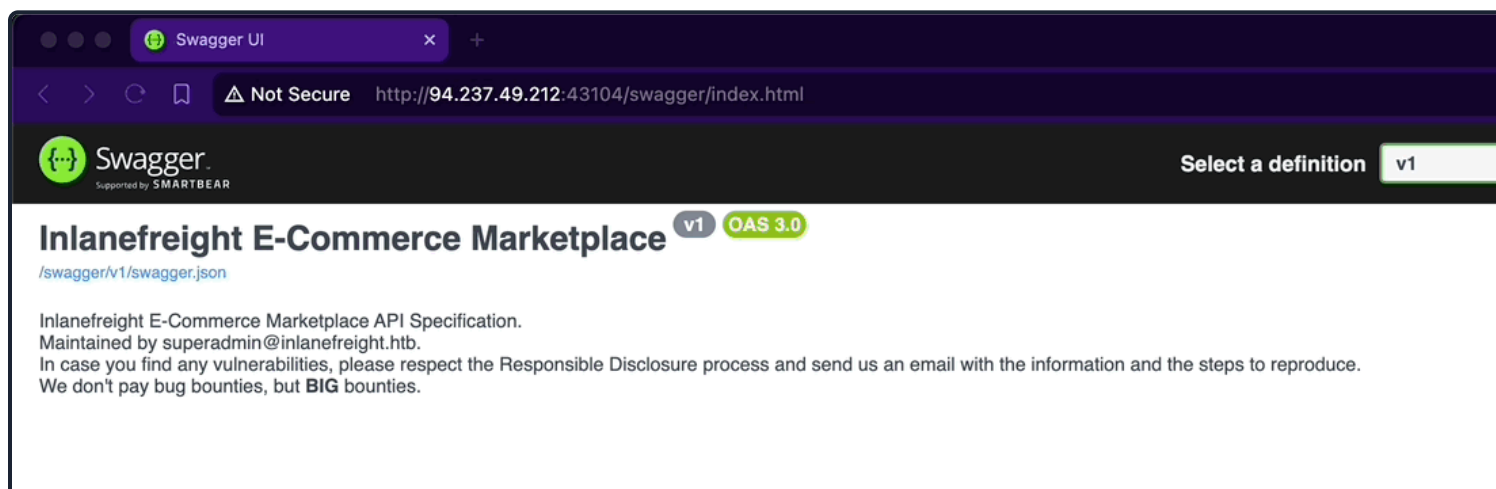
Authorization Bypass Through User-Controlled Key

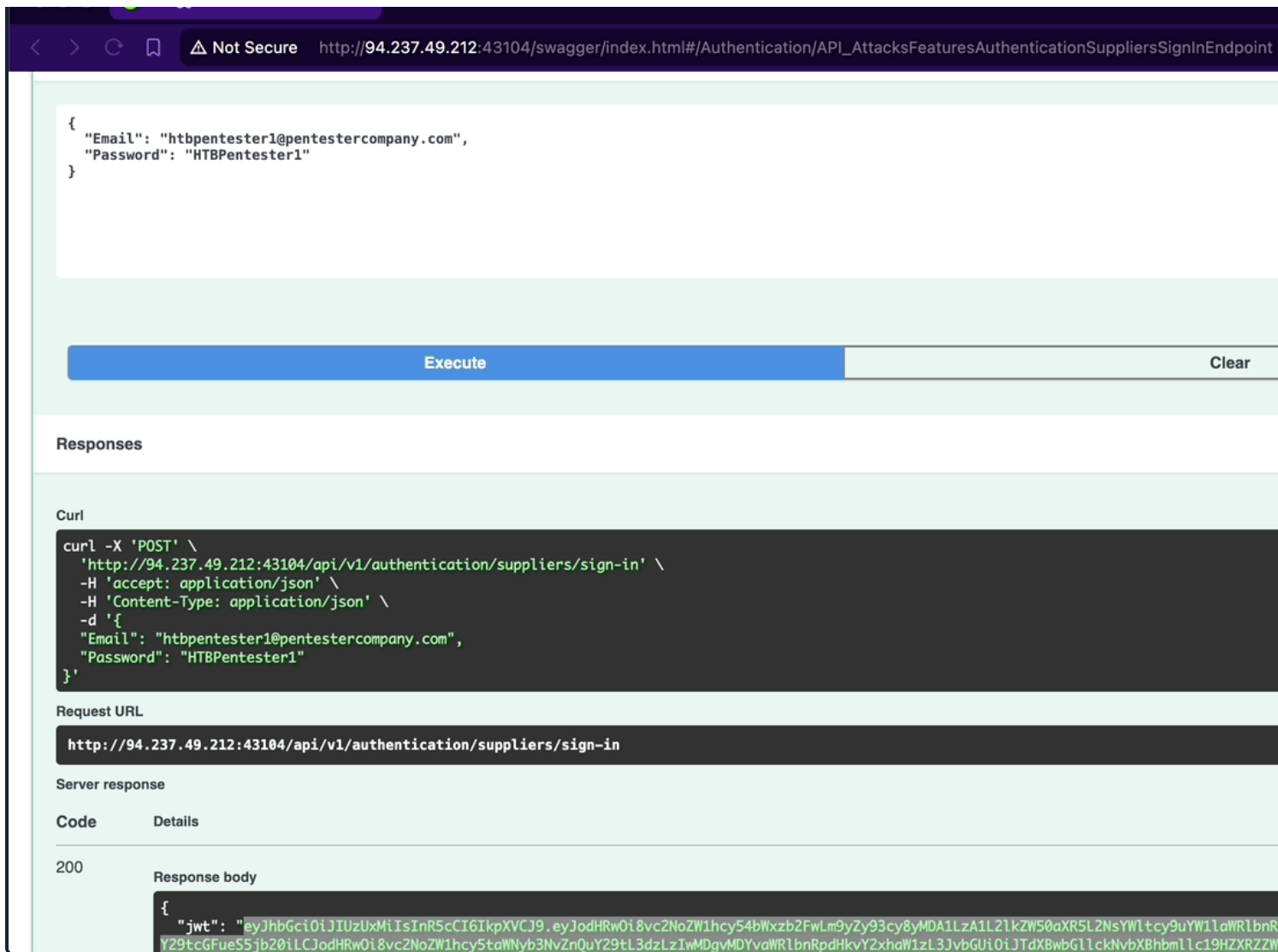
The endpoint we will be practicing against is vulnerable to [CWE-639: Authorization Bypass Through User-Controlled Key](#).

Scenario

The admin of Inlanefreight E-Commerce Marketplace has provided us with the credentials `htbpentester1@pentestercompany.com:HTBPentester1`, wanting us to assess what API vulnerabilities they have and what roles are assigned to them.

Because the account belongs to a Supplier, we will utilize the `/api/v1/authentication/suppliers/signin` endpoint to obtain a JWT:





The image shows a Swagger UI interface in a web browser. The address bar displays the URL: `http://94.237.49.212:43104/swagger/index.html#/Authentication/API_AttacksFeaturesAuthenticationSuppliersSignInEndpoint`. The interface shows a JSON body for a POST request:

```
{  "Email": "htbpentester1@pentestercompany.com",  "Password": "HTBPentester1"}
```

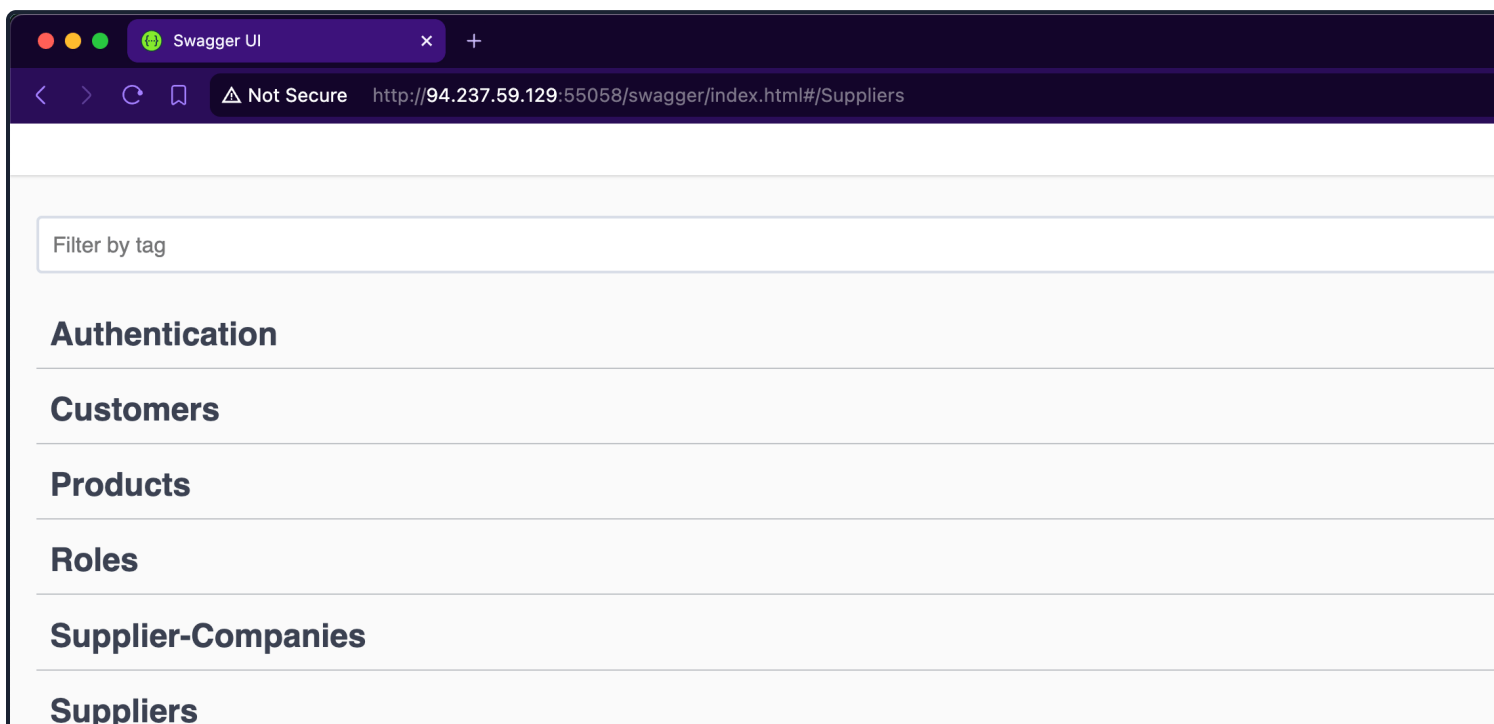
Below the body, there is an **Execute** button and a **Clear** button. Under the **Responses** section, the **Curl** command is displayed:

```
curl -X 'POST' \  'http://94.237.49.212:43104/api/v1/authentication/suppliers/sign-in' \  -H 'accept: application/json' \  -H 'Content-Type: application/json' \  -d '{  "Email": "htbpentester1@pentestercompany.com",  "Password": "HTBPentester1"  }'
```

The **Request URL** is `http://94.237.49.212:43104/api/v1/authentication/suppliers/sign-in`. The **Server response** section shows a **Code** of 200 and a **Response body** containing a JWT token:

```
{  "jwt": "eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vc2NoZW1hcy54bWxzb2FwLm9yZy93cy8yMDA1LzA1L2lkZW50aXR5L2NsYW1tcy9uYW1aWR1bnR5Z9tcGFueS5jb20iLCJodHRwOi8vc2NoZW1hcy5taWY3N3NvZnQuY29tL3dzLzIwMDgvMDYvaWR1bnRpdHkvY2xhaW1zL3JvbGUiOiJTdXBwbGlckNvbXBhbm1lc19HZXRZZW"}
```

When examining the endpoints within the Suppliers group (notice how they have a lock at their right-most authentication is required), we will notice one named `/api/v1/suppliers/current-user`:



The image shows a Swagger UI interface in a web browser. The address bar displays the URL: `http://94.237.59.129:55058/swagger/index.html#/Suppliers`. The interface shows a **Filter by tag** input field. Below the input field, there is a list of tags:

- Authentication
- Customers
- Products
- Roles
- Supplier-Companies
- Suppliers

Let us then retrieve our current user's roles. After invoking the `/api/v1/roles/current-user` endpoint, it returns the following response:

```

{
  "roles": [
    {
      "role": "SupplierCompanies_GetYearlyReportByID"
    }
  ]
}
```

Swagger UI

Not Secure http://94.237.59.129:55058/swagger/index.html#/Roles/API_AttacksFeaturesRolesGetByCurrentUserEndpoint

Roles

GET

/api/v1/roles/current-user

Get the roles of the currently authenticated user

Use this endpoint to get the roles of the currently authenticated user.
Role(s) required: **None**

Parameters

No parameters

Execute

Clear

Responses

Curl

```
curl -X 'GET' \
```

API endpoints for Supplier Companies:

- PATCH** `/api/v1/supplier-companies` Updates a Supplier Company
- GET** `/api/v1/supplier-companies` Gets all Supplier Companies
- POST** `/api/v1/supplier-companies` Creates a new Supplier Company
- GET** `/api/v1/supplier-companies/{ID}` Gets a Supplier Company
- GET** `/api/v1/supplier-companies/{ID}/certificates-of-incorporation` Gets a Supplier's Company Certificate of Incorporation as Base64
- POST** `/api/v1/supplier-companies/certificates-of-incorporation` Uploads a Supplier's Company Certificate of Incorporation
- GET** `/api/v1/supplier-companies/current-user` Gets the Supplier Company of the currently authenticated Supplier
- GET** `/api/v1/supplier-companies/yearly-reports` Gets all Supplier Companies Yearly Reports
- GET** `/api/v1/supplier-companies/yearly-reports/{ID}` Gets a Supplier Company Yearly Report

Suppliers

Schemas

When expanding it, we will notice that it requires the `SupplierCompanies_GetYearlyReportByID` role and an integer and not a `Guid`:

Swagger UI expanded view of the endpoint `GET /api/v1/supplier-companies/yearly-reports/{ID}`.

Role(s) required: `SupplierCompanies_GetYearlyReportByID`

Parameters

Name	Description
ID * required <code>integer(int32)</code> (path)	ID

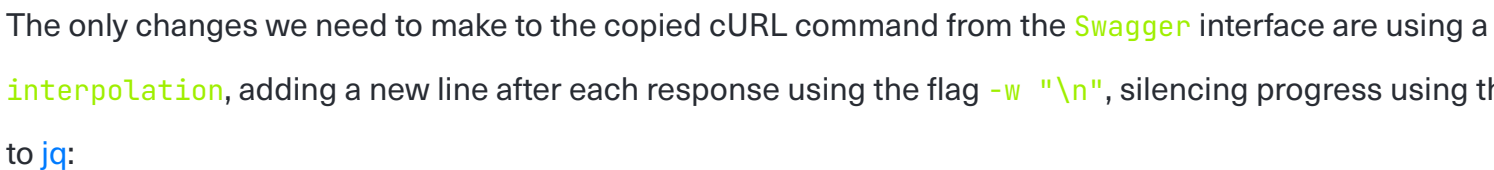
Execute

Responses

Code	Description
200	Success

When trying other IDs, we still can access yearly reports of other supplier-companies, allowing us to access data:

[illegible]

[illegible]

Start Instance

∞ / 1 spawns left



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): Fetching status...



Authenticate to with user "htbpentester2@pentestercompany.com" and password "HTBPentester2"

+ 0

Exploit another Broken Object Level Authorization vulnerability and submit the flag.

Submit your answer here...

+10 Streak pts

Submit

-  Unrestricted Resource Consumption
-  Broken Function Level Authorization
-  Unrestricted Access to Sensitive Business Flows
-  Server Side Request Forgery
-  Security Misconfiguration
-  Improper Inventory Management
-  Unsafe Consumption of APIs

Skills Assessment

-  Skills Assessment

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left